

### **Addressing Risks and Opportunities (Clause 6.1.1)**

1. Risks: Unwanted events that can negatively impact information security (e.g., floods damaging paper records).
2. Opportunities: Actions that can improve information security (e.g., hiring a trained expert).
3. Actions:
  - a. Plan how to address risks and opportunities.
  - b. Integrate these actions into the ISMS.
  - c. Evaluate the effectiveness of these actions.
4. Examples:
  - a. Risk: Include in the regular risk management process.
  - b. Opportunity: Part of continual improvement (e.g., setting objectives for employees to gain security certifications).
5. Importance:
  - a. Managing risks and opportunities strengthens the ISMS and business operations by addressing weaknesses and leveraging strengths.

### **Risk Management Process (Clause 6.1.2)**

1. Risk Assessment Methodology:
  - b. Document the methodology to ensure consistent assessments.
  - c. Define criteria for risk assessment and risk acceptance.
  - d. Establish the company's risk appetite (what constitutes acceptable risk).
2. Risk Assessment:
  - a. Identify, analyze, and evaluate information security risks.
3. Risk Treatment:
  - b. Choose mitigation strategies for unacceptable risks.
4. Statement of Applicability:
  - c. A mandatory document listing all information security controls.
5. Risk Treatment Plan:
  - d. A mandatory document outlining how to implement controls to address risks.

## **Information Security Risk Assessment: Risk Identification (Class 6.1.2)**

According to ISO 27001, the risk assessment involves three key elements: Risk Identification, Risk Analysis, and Risk Evaluation.

Risk Identification:

Key Points:

1. Asset-Based Risk Assessment: This method identifies what needs protection, including:
  - e. Assets: Hardware, software, information (both electronic and paper), infrastructure, and people.
  - f. Threats: Events that could negatively impact assets, such as:
    - g. Fire
    - h. Earthquakes
    - i. Computer viruses
    - j. Employee turnover
  - k. Vulnerabilities: Weaknesses that allow threats to materialize, such as:
    - l. Lack of fire extinguishing systems
    - m. Absence of business continuity plans
    - n. No antivirus software
    - o. Outdated equipment
2. Risk Ownership: For each identified risk, assign a risk owner who is responsible for managing that risk.
3. Documentation: ISO 27001 requires documenting the results of the risk assessment.

Example:

- a. Asset: Server
- b. Identified Threat: Electricity outage
- c. Vulnerability: Lack of an Uninterruptible Power Supply (UPS)
- d. Risk Summary: If there is an electricity outage, the server will become temporarily unavailable due to the absence of a UPS.

This structured approach helps organizations understand the risks they face, enabling them to effectively evaluate and treat these risks in their Information Security Management System (ISMS).

## **Information Security Risk Assessment: Risk Analysis and Evaluation (Class 6.1.2)**

The next steps in the risk assessment process involve Risk Analysis and Risk Evaluation. Here's a simplified overview:

Key Points:

1. Risk Analysis:
  - a. Assessment of Impact: Evaluate how the risk could affect the asset, specifically regarding the confidentiality, integrity, and availability of information.
  - b. Example: If the server is down, the information stored is unavailable, impacting availability.
  - c. If unauthorized persons access a paper document, it jeopardizes confidentiality.
  - d. Assessment of Likelihood: Estimate how likely the risk is to occur. Companies can use different scales for this assessment (e.g., high/medium/low or numerical values like 1 to 5).
  - e. Documentation: All assessment scales and methods must be documented in the risk assessment methodology.
2. Risk Level Determination:
  - a. The risk level can be calculated by:
    - b. Multiplying impact and likelihood.
    - c. Adding them together.
  - d. This calculation method should also be documented.
3. Risk Evaluation:
  - a. Determine which risks are acceptable based on the established criteria.
  - b. Risks that are not acceptable must be addressed in the next step of risk management.

Example:

- a. Identified Risk: Temporary unavailability of the server.
- b. Impact Assessment:
- c. Impact on Availability: Rated as 4 (on a scale of 1 to 5), indicating a high

impact.

- a. Likelihood Assessment: Rated as 2, based on historical data.
- b. Risk Level Calculation:
- c. Risk Level: 6 (calculated by adding impact (4) and likelihood (2)).

Evaluation:

- a. If the acceptable risk level is 6, this risk is considered acceptable, meaning no further treatment is necessary. Risks rated 7 or higher will require treatment.

This structured approach to analyzing and evaluating risks is essential for effective risk management in an Information Security Management System (ISMS).

## **Information Security Risk Treatment (Class 6.1.3)**

After identifying unacceptable risks from the risk assessment, the next step is to choose appropriate risk treatment options. This is a critical phase, as it often involves significant financial investment in the ISO 27001 project. Here are the key points:

### **Key Points:**

1. Importance of Control Selection:
  - b. Selecting the right controls is essential for both security and business viability.
2. Common Risk Treatment Options:
  - c. Decrease the Risk: Implement controls to reduce the likelihood or impact of the risk.
  - d. Example: For the risk of server unavailability due to power outages, install Uninterruptible Power Supplies (UPS) and backup generators.
  - e. Accept the Risk: Choose to accept the risk when treatment costs exceed the potential financial impact.
  - f. Example: Accept the risk of minor data loss if recovering it is more expensive than the data itself.
  - g. Avoid the Risk: Eliminate the risk entirely when feasible, often by ceasing the activity that creates the risk.
  - h. Example: If securing remote connections for teleworking is too costly compared to the benefits, consider discontinuing remote work.
  - i. Transfer the Risk: Shift the risk to another party, typically through outsourcing or insurance.
  - j. Example: Outsource HR functions or purchase insurance for fire and flood damage. However, remember that transferring risk does not absolve the company from its consequences.
3. Selecting Relevant Controls:
  - a. For risks chosen to be decreased, select appropriate controls from Annex A of the ISO 27001 standard, which lists 93 potential controls.
  - b. Companies may also implement additional controls that are not specified in Annex A.
4. Documentation Requirement:
  - a. Document the results of the risk treatment process in a risk treatment sheet or through a risk management tool, as mandated by the standard.

This structured approach ensures that the organization effectively manages its information security risks, balancing security measures with financial implications.

### **Statement of Applicability (Class 6.1.3)**

The Statement of Applicability (SOA) is a critical document in the Information Security Risk Management process, as required by ISO 27001. Here are the key points:

#### **Key Points:**

1. Definition and Purpose:
  - b. The SOA outlines the security profile of the organization.
  - c. It lists all applicable controls from Annex A of ISO 27001, as well as any additional controls identified during the risk treatment process.
2. Content Requirements:
  - a. For each control, the SOA must include:
  - b. Implementation Status: Whether the control is already implemented.
  - c. Reason for Implementation: Justification for why the control is necessary.
  - d. Implementation Details: How the control is executed.
  - e. Justification for Exclusion: Explanation for any controls that are not applicable.
3. Role in Certification:
  - a. The SOA serves as a key reference for certification auditors during the audit process.
4. Example:
  - b. Implemented Control: Information classification control is in place as a best practice, with implementation described in the classification guideline.
  - c. Non-Implemented Control: A control for secure areas is not implemented because the company uses cloud servers and has no physical server room, justifying its exclusion.
5. Additional Criteria for Control Selection:
  - a. Controls may also be deemed applicable based on requirements from interested parties, even if no specific risks are identified.
  - b. Justifications for applying controls can reference related risks, management decisions, and other relevant factors.

The SOA is vital for demonstrating compliance with ISO 27001 and for guiding the organization's security practices.

### **Risk Treatment Plan (Clause 6.1.3)**

The Risk Treatment Plan is the final step in the risk management process as outlined by ISO 27001. Here are the key points:

Key Points:

1. Definition:
  - a. The Risk Treatment Plan documents all the controls selected for implementation, along with relevant details.
2. Purpose:
  - b. It specifies who will implement each control, the time frame for implementation, and the budget allocated for each control.
3. Connection to PDCA Cycle:
  - c. This plan serves as a critical link between the Plan and Do phases of the PDCA (Plan-Do-Check-Act) cycle, emphasizing its role in the overall management framework.
4. Documentation Requirements:
  - d. The plan must detail the implementation process to ensure clear accountability and effective tracking of security measures.

The Risk Treatment Plan is essential for ensuring that identified security controls are effectively put into practice within the organization.